Risk management – where do we start?

Author

Bhavik D.

Published: 5 February 2024

Risk management has never been more important than it is now. Today's global risk landscape has a wide range of more complex risks that hit harder, come faster, are interlinked, and bring more profound disruptions.

Recent events have significantly changed the business environment, such as the COVID-19 pandemic, wars, and supply chain disruption. This, alongside the now-pervasive use of digital technology, makes identifying and mitigating risks a challenge for any business.

This blog introduces the principles of risk management and gives an update on our refreshed maturity model. It will be the first in a series of blogs we are planning on this topic.

What is risk management?

Risk management is a crucial aspect of an entity's decision-making that involves identifying, assessing, and mitigating potential risks to achieving strategic objectives. It's fundamental to good governance and needs to be reflected in the behaviours and culture of the an organisation.

Entities can develop a robust framework for managing risks by following the process below, tailoring it based on their work, size, complexity, and risk profile.

1. Identify risks

Identify and document potential risks your entity is exposed to, regardless of the existing controls in place. These can arise from various sources, such as internal processes, external factors, regulatory changes, or technological advancements. You should keep the resulting list up-to-date in a risk register.

2. Analyse likelihood and possible impact

Assess the identified risks by considering the probability of each one occurring and estimating the severity of its consequences. Using a risk matrix to categorise risks based on their significance allows your entity to focus on managing the most critical ones.

3. Evaluate and prioritise risks

Compare the significance of each risk against the level of risk your entity is willing to accept (this is your risk appetite) to determine the priority of risks requiring treatment. Entities must define their risk appetite, quantify what they will tolerate, and integrate these statements into their risk management processes.

4. Treat or respond to the risk conditions

Develop and implement strategies to address identified risks. Entities may consider accepting, avoiding, mitigating, or transferring risks based on their risk tolerance and objectives. Weigh up the cost against the benefit for your entity and document the agreed response in a risk treatment plan.

5. Monitor and review the results of risk controls

Continuously monitor and reassess your identified risks and the effectiveness of risk treatments through regular audits, reviews, and the use of key performance indicators. This ensures your entity remains adaptable to changing conditions and can respond promptly to emerging risks.

6. Communicate and report to stakeholders

Communicate risk information to relevant stakeholders and regularly report on the status of identified risks, treatments, and overall risk management effectiveness. This contributes to maintaining transparency and accountability, and fosters a more risk-aware culture within the your organisation.

How to identify and plan for risks

Conducting a thorough exploration and identification of potential risks is critical to the success of any risk assessment. Finding potential risks to your business can be as easy as thinking about what can go wrong, how, and why.

Consider these practices to help identify and plan for risks:

- Integrate risk management into overall business processes. It must not occur in isolation.
- Have a proactive attitude. It's never too soon to start thinking about risk.
- Encourage open dialogue, and empower all staff to speak out and take action.
- Gather input from all stakeholders, including independent and subject matter experts, to gain different perspectives and uncover a broader range of risks.
- Use different techniques to generate a comprehensive list of internal and external risks. This includes
  - brainstorming sessions
  - SWOT (strengths, weaknesses, opportunities, threat) analysis
  - scenario planning to explore risks from potential future situations
  - data analysis to identify patterns and recurring issues
- Learn from past successes and failures, and use this information to improve planning and future decision-making
- Document all risks in a risk register, assign who is responsible for what, and appoint a risk owner.

Want to assess your current risk management practices?

We have recently updated our *Risk management maturity model*, which outlines 4 levels of maturity across 5 components of risk management. Your entity can use it to self-assess your risk management maturity.

In our report *Education 2022* (Report 16: 2022–23), we used this maturity model to assess universities' risk management practices. We found they are generally effective, but could be improved. They could benefit from having a central system that automates the recording and monitoring of risks. This would give them a big-picture view of risk across their businesses.

Queensland departments that experienced subject to recent machinery of government changes may also benefit from using the model now.

Where to from here?

Good risk management supports the better delivery of services through more effective decision-making, greater preparedness for unexpected events, and encourages innovation.

As entities identify risks and commit to effectively managing them, they are better positioned to achieve their strategic and operational objectives.

Look out for the next blog in our risk management series on effective risk registers.

Resources

Reports to parliament

- *Education 2022* (Report 16: 2022–23)
- *Local government 2022* (Report 15: 2022–23)
- *Major projects 2022* (Report 7: 2022–23)
- *2022 status of Auditor-General's recommendations* (Report 4: 2022–23)
- *Contract management for new infrastructure* (Report 16: 2021–22)
- *Appointing and renewing government boards* (Report 17: 2021–22)
- *Effectiveness of audit committees in state government entities* (Report 2: 2020–21)
- *Regulating dam safety* (Report 9: 2021–22)
- *Evaluating major infrastructure projects* (Report 14: 2019–20)
  Fraud risk management (Report 6: 2017–18)

- *Managing cyber security risks* (Report 3: 2019–20).
-

Blog

- *Using risk appetite in the public sector*
- *Tips on finding right people for governance boards*
- *How can audit committees improve audit quality?*
- *You have an audit committee but is it effective?*
- *The importance of culture*
- *Role of governance committees in managing cyber security risks*
- *Risk of underpayment of payroll*
- *Are climate-related risks impacting your financial statements?*
- *Delivering efficient and effective local government services*
- *How you can manage the risk of your legacy systems*
- *The importance of developing effective strategies*
- *Better practices for regulators – plan to be intelligence-led.*

Related article

Using risk appetite in the public sector

Published: 3 September 2020

Risk appetite and risk tolerance continue to be important conversations in how the public sector applies risk management practices.

Subscribe to our news and blog

Email

Name

Subscribe

Copyright © 2026 Queensland Audit Office.

We acknowledge the Traditional Custodians of the land on which we operate, live and gather as employees, and recognise their continuing connection to land, water and community. We pay respect to Elders past, present and emerging.